

Incident Response Plan

Scenario: A staff member clicked a suspicious link on a personal device that is connected to the company's network. Because the company stores sensitive medical insurance records, this incident is treated as High Risk due to the possibility of malware infection or unauthorised access to confidential customer data.

1. Detection

- Confirm the incident by interviewing the employee about what happened.
- Check the device for unusual behaviour, such as unexpected pop-ups, unknown programs, or network activity.
- Review antivirus alerts, system logs, and network monitoring tools to determine whether malicious activity has occurred.

2. Analysis

- Identify the type of attack (e.g., phishing, malware, or ransomware).
- Determine whether sensitive medical records, company credentials, or other systems have been accessed.
- Record all findings, including the time of the incident, affected systems, and evidence collected for future investigation.

3. Containment

- Immediately disconnect the affected device from the company network and disable its access to shared resources.
- Reset the employee's passwords and temporarily suspend affected accounts if necessary.
- Notify management and the incident response team so they can assess whether regulatory reporting is required.

4. Eradication

- Remove the malware using approved security software or rebuild the device if necessary.
- Install the latest operating system and security updates.
- Scan other devices on the network to confirm that the threat has not spread.

Incident Response Team Roles

- Cyber Security Analyst: Leads the investigation, analyses evidence, and coordinates the response.
- IT Support: Isolates the device, removes malware, restores systems, and applies security updates.
- Management: Makes business decisions, approves communications, and ensures legal compliance.
- Legal/Compliance Officer: Determines whether data protection authorities or affected customers must be notified.

Severity

This incident is classified as High Severity because a successful compromise could expose confidential medical records, disrupt business operations, and lead to legal penalties. Recovery is only complete after the device is confirmed clean, systems are monitored for further threats, and the employee receives phishing awareness training.